



OWASP Top Ten (Core)

Olubukola Omotayo
Coding Dojo Cybersecurity Boot Camp
14th March 2024



OWASP Top Ten (Core)



Learning Objectives:

- Research current security vulnerabilities.
- Determine the most appropriate mitigation to a security vulnerability.

Research the OWASP top 10 that are current. After you have this, research the impact of each of the 10 vulnerabilities. Make sure to use APA citations for your sources (yes including the OWASP website). Each vulnerability should have **at least 1 paragraph** explaining the impacts and how the vulnerability can be mitigated.

Assignment Submission

Upload a single document including the requirements above with APA citations. If there are no citations the assignment will not be accepted.

Assignment Solution:

Open Web Application Security Project, OWASP

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

Companies should adopt this document and start the process of ensuring that their web applications minimize these risks. Using the OWASP Top 10 is perhaps the most effective first step towards changing the software development culture within your organization into one that produces more secure code.

Here are the impacts and mitigation strategies for each of the OWASP Top 10 vulnerabilities for 2021, along with APA citations for the sources:

1. Broken Access Control (A01:2021)

- **Impact:** Inadequate access controls can lead to unauthorized access to sensitive data or functionality, allowing attackers to view, modify, or delete information or perform actions not intended for their role.
- **Mitigation:** Implement proper access controls, such as role-based access control (RBAC), least privilege principle, and strong authentication mechanisms. Regularly review and audit access control configurations to identify and remediate misconfigurations.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

2. Cryptographic Failures (A02:2021)

- **Impact:** Cryptographic vulnerabilities, such as weak encryption algorithms or improper key management, can result in data breaches, unauthorized data disclosure, and compromised confidentiality and integrity of sensitive information.
- **Mitigation:** Use strong encryption algorithms and key lengths, implement secure key management practices, and adhere to cryptographic best practices and standards. Regularly update cryptographic libraries and algorithms to address known vulnerabilities.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

3. Injection (A03:2021)

- **Impact:** Injection flaws, including SQL injection, OS command injection, and LDAP injection, allow attackers to execute arbitrary commands or code within an application, leading to data leakage, data loss, and unauthorized access.
- **Mitigation:** Employ input validation, parameterized queries, and prepared statements to mitigate injection attacks. Use secure coding practices and automated tools to detect and prevent injection vulnerabilities during development.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

4. Insecure Design (A04:2021)

- **Impact:** Insecure design decisions, such as lack of security controls or trust boundaries, can result in vulnerabilities throughout the application lifecycle, leading to exploitation, data breaches, and compromise of critical assets.
- **Mitigation:** Implement secure design principles, threat modeling, and security architecture reviews early in the development process. Continuously assess and improve the security posture of the application through regular security assessments and code reviews.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

5. Security Misconfiguration (A05:2021)

- **Impact:** Security misconfigurations, such as default settings, open ports, or excessive permissions, can expose systems to unauthorized access, data breaches, and other security threats.
- **Mitigation:** Follow secure configuration guides and best practices for servers, frameworks, and applications. Automate configuration management and regularly audit and monitor configurations for deviations from the desired secure state.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

6. Vulnerable and Outdated Components (A06:2021)

- **Impact:** Using outdated or vulnerable third-party libraries, frameworks, or components can introduce security vulnerabilities into an application, making it susceptible to known attacks and exploitation.
- **Mitigation:** Regularly update and patch dependencies to the latest secure versions. Monitor vulnerability databases and subscribe to security advisories to stay informed about potential vulnerabilities in third-party components. Employ software composition analysis tools to identify and remediate vulnerable components.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

7. Identification and Authentication Failures (A07:2021)

- **Impact:** Weak or ineffective identification and authentication mechanisms can lead to unauthorized access, account takeover, and compromise of sensitive data or functionality.
- **Mitigation:** Implement multi-factor authentication (MFA), strong password policies, and session management controls. Enforce secure password storage and transmission practices, such as hashing and encryption. Conduct regular authentication audits and enforce account lockout policies to prevent brute-force attacks.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

8. Software and Data Integrity Failures (A08:2021)

- **Impact:** Failures in software and data integrity controls can result in unauthorized modification, deletion, or corruption of critical data or code, leading to service disruptions, data loss, or unauthorized access.
- **Mitigation:** Implement integrity checks, digital signatures, and tamper-evident logging mechanisms to detect and prevent unauthorized modifications to software and data. Use secure coding practices and code signing to ensure the integrity of software components and updates.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

9. Security Logging and Monitoring Failures (A09:2021)

- **Impact:** Inadequate logging and monitoring capabilities can hinder the detection and response to security incidents, allowing attackers to operate undetected and prolonging the duration of attacks.
- **Mitigation:** Implement comprehensive logging and monitoring solutions to capture and analyze security-relevant events and activities. Define and enforce logging policies, including log retention periods and access controls. Establish incident response procedures and conduct regular security incident drills to validate logging and monitoring effectiveness.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

10. **Server-Side Request Forgery (A10:2021)**

- **Impact:** Server-Side Request Forgery (SSRF) vulnerabilities allow attackers to send crafted requests from the vulnerable server, potentially leading to unauthorized access to internal systems, data leakage, or service disruption.
- **Mitigation:** Validate and sanitize user-supplied input, especially when making requests to external or internal resources. Implement whitelisting of allowed URLs or domains to restrict the destinations of server-side requests. Employ network segmentation and access controls to minimize the impact of successful SSRF attacks.
- **Source:** OWASP. (2021). OWASP Top Ten. Retrieved from <https://owasp.org/www-project-top-ten/>

These vulnerabilities underscore the importance of robust security practices, secure coding techniques, and continuous monitoring to mitigate the risk of cyber threats and protect critical assets and data.

Instructor's Assessment:

The screenshot shows the Coding Dojo interface. The top navigation bar includes the Coding Dojo logo, a search bar, and links for HOME, LEARN, and CONTACT. Below this is a secondary navigation bar with links for Courses, Unit, Assignment Checklist (which is highlighted), Stats, and Take Exams. On the left, there is a sidebar with course listings: CYBERSECURITY CORE V22 PART-TIME, CYBERSECURITY INTERMEDIATE V22 PART-TIME, and CYBERSECURITY BONUS SKILLS. The main content area displays a table of assignments for a user named Richard F. A modal window is open over the first row, showing the user's name, date, and a detailed assessment comment.

Assignment	Type	Due Date	Completed	Difficulty	Est. Time
CYBERSECURITY INTERMEDIATE V22 PART-TIME	Intermediate 4 - PT - V22	OWASP Research	100%		
Intermediate 3 - PT - V22			100%		
Intermediate 4 - PT - V22			100%		

This block provides a detailed view of the assessment comment for Richard F. It includes the user's name, date, and the specific assignment being assessed. The comment is: "Check +. Nice presentation and detail."

Richard F.
Mar 14, 2024
CYBERSECURITY INTERMEDIATE V22 PART-TIME >
Intermediate 4 - PT - V22 > OWASP Research

Check +. Nice presentation and detail.